

CONTROL 6

Access Control Management

Safeguards: 8	IG1: 5/8	IG2: 7/8	IG3: 8/8
---------------	----------	----------	----------

Overview

Use processes and tools to create, assign, manage, and revoke access credentials and privileges for user, administrator, and service accounts for enterprise assets and software.

Why is this Control critical?

Where CIS Control 5 deals specifically with account management, CIS Control 6 focuses on managing what access these accounts have, ensuring users only have access to the data or enterprise assets appropriate for their role, and ensuring that there is strong authentication for critical or sensitive enterprise data or functions. Accounts should only have the minimal authorization needed for the role. Developing consistent access rights for each role and assigning roles to users is a best practice. Developing a program for complete provision and de-provisioning access is also important. Centralizing this function is ideal.

There are some user activities that pose greater risk to an enterprise, either because they are accessed from untrusted networks, or performing administrator functions that allow the ability to add, change, or remove other accounts, or make configuration changes to operating systems or applications to make them less secure. This also enforces the importance of using MFA and Privileged Access Management (PAM) tools.

Some users have access to enterprise assets or data they do not need for their role; this might be due to an immature process that gives all users all access, or lingering access as users change roles within the enterprise over time. Local administrator privileges to users’ laptops is also an issue, as any malicious code installed or downloaded by the user can have greater impact on the enterprise asset running as administrator. User, administrator, and service account access should be based on enterprise role and need.

Procedures and tools

There should be a process where privileges are granted and revoked for user accounts. This ideally is based on enterprise role and need through role-based access. Role-based access is a technique to define and manage access requirements for each account based on: need to know, least privilege, privacy requirements, and/or separation of duties. There are technology tools to help manage this process. However, there might be more granular or temporary access based on circumstance.

MFA should be universal for all privileged or administrator accounts. There are many tools that have smartphone applications to perform this function, and are easy to deploy. Using the number-generator feature is more secure than just sending a Short Messaging Service (SMS) message with a one-time code, or prompting a “push” alert for a user to accept. However, neither is recommended for privileged account MFA. PAM tools are available for privileged account control, and provide a one-time password that must be checked out for each use. For additional security in system administration, using “jump-boxes” or out of band terminal connections is recommended.

Comprehensive account de-provisioning is important. Many enterprises have repeatable consistent processes for removing access when employees leave the enterprise. However, that process is not always consistent for contractors, and must be included in the standard de-provisioning process. Enterprises should also inventory and track service accounts, as a common error is leaving clear text tokens or passwords in code, and posting to public cloud-based code repositories.

High-privileged accounts should not be used for day-to-day use, such as web surfing and email reading. Administrators should have separate accounts that do not have elevated privileges for daily office use, and should log into administrator accounts only when performing administrator functions requiring that level of authorization. Security personnel should periodically gather a list of running processes to determine whether any browsers or email readers are running with high privileges.

An excellent resource is the NIST® Digital Identity Guidelines: <https://pages.nist.gov/800-63-3/>

Safeguards

Safeguard 6.1: Establish an Access Granting Process

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and follow a documented process, preferably automated, for granting access to enterprise assets upon new hire or role change of a user.

Safeguard 6.2: Establish an Access Revoking Process

Asset Type: Documentation	Security Function: Govern	IG1	IG2	IG3
---------------------------	---------------------------	-----	-----	-----

Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.

Safeguard 6.3: Require MFA for Externally-Exposed Applications

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.

Safeguard 6.4: Require MFA for Remote Network Access

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Require MFA for remote network access.

Safeguard 6.5: Require MFA for Administrative Access

Asset Type: Users	Security Function: Protect	IG1	IG2	IG3
-------------------	----------------------------	-----	-----	-----

Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a service provider.

Safeguard 6.6: Establish and Maintain an Inventory of Authentication and Authorization Systems

Asset Type: Software	Security Function: Identify	IG2	IG3
----------------------	-----------------------------	-----	-----

Establish and maintain an inventory of the enterprise’s authentication and authorization systems, including those hosted on-site or at a remote service provider. Review and update the inventory, at a minimum, annually, or more frequently.

Safeguard 6.7: Centralize Access Control

Asset Type: Users	Security Function: Protect	IG2	IG3
-------------------	----------------------------	-----	-----

Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.

Safeguard 6.8: Define and Maintain Role-Based Access Control

Asset Type: Users	Security Function: Govern	IG3
-------------------	---------------------------	-----

Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.

CONTROL 7

Continuous Vulnerability Management

Safeguards: 7	IG1: 4/7	IG2: 7/7	IG3: 7/7
---------------	----------	----------	----------

Overview

Develop a plan to continuously assess and track vulnerabilities on all enterprise assets within the enterprise’s infrastructure, in order to remediate, and minimize, the window of opportunity for attackers. Monitor public and private industry sources for new threat and vulnerability information.

Why is this Control critical?

Cyber defenders are constantly being challenged from attackers who are looking for vulnerabilities within their infrastructure to exploit and gain access. Defenders must have timely threat information available to them about: software updates, patches, security advisories, threat bulletins, etc., and they should regularly review their environment to identify these vulnerabilities before the attackers do. Understanding and managing vulnerabilities is a continuous activity, requiring focus of time, attention, and resources.

Attackers have access to the same information and can often take advantage of vulnerabilities more quickly than an enterprise can remediate. While there is a gap in time from a vulnerability being known to when it is patched, defenders can prioritize which vulnerabilities are most impactful to the enterprise, or likely to be exploited first due to ease of use. For example, when researchers or the community report new vulnerabilities, vendors have to develop and deploy patches, indicators of compromise (IOCs), and updates. Defenders need to assess the risk of the new vulnerability to the enterprise, regression-test patches, and install the patch.

There is never perfection in this process. Attackers might be using an exploit to a vulnerability that is not known within the security community. They might have developed an exploit to this vulnerability referred to as a “zero-day” exploit. Once the vulnerability is known in the community, the process mentioned above starts. Therefore, defenders must keep in mind that an exploit might already exist when the vulnerability is widely socialized. Sometimes vulnerabilities might be known within a closed community (e.g., vendor still developing a fix) for weeks, months, or years before it is disclosed publicly. Defenders have to be aware that there might always be vulnerabilities they cannot remediate, and therefore need to use other controls to mitigate.

Enterprises that do not assess their infrastructure for vulnerabilities and proactively address discovered flaws face a significant likelihood of having their enterprise assets compromised. Defenders face particular challenges in scaling remediation across an entire enterprise, and prioritizing actions with conflicting priorities, while not impacting the enterprise's business or mission.

Procedures and tools

A large number of vulnerability scanning tools are available to evaluate the security configuration of enterprise assets. Some enterprises have also found commercial services using remotely managed scanning appliances to be effective. To help standardize the definitions of discovered vulnerabilities across an enterprise, it is preferable to use vulnerability scanning tools that map vulnerabilities to one or more of the following industry-recognized vulnerability, configuration, and platform classification schemes and languages: Common Vulnerabilities and Exposures (CVE®), Common Configuration Enumeration (CCE), Open Vulnerability and Assessment Language (OVAL®), Common Platform Enumeration (CPE), Common Vulnerability Scoring System (CVSS), and/or Extensible Configuration Checklist Description Format (XCCDF).

More information on SCAP can be found here: <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-126r3.pdf>

The frequency of scanning activities should increase as the diversity of an enterprise's assets increases to account for the varying patch cycles of each vendor. Advanced vulnerability scanning tools can be configured with user credentials to authenticate into enterprise assets and perform more comprehensive assessments. These are called "authenticated scans."

In addition to the scanning tools that check for vulnerabilities and misconfigurations across the network, various free and commercial tools can evaluate security settings and configurations of enterprise assets. Such tools can provide fine-grained insight into unauthorized changes in configuration or the inadvertent introduction of security weaknesses from administrators.

Effective enterprises link their vulnerability scanners with problem-ticketing systems that track and report progress on fixing vulnerabilities. This can help highlight unmitigated critical vulnerabilities to senior management to ensure they are resolved. Enterprises can also track how long it took to remediate a vulnerability, after identified, or a patch has been issued. These can support internal or industry compliance requirements. Some mature enterprises will go over these reports in IT security steering committee meetings, which bring leaders from IT and the business together to prioritize remediation efforts based on business impact.

In selecting which vulnerabilities to fix, or patches to apply, an enterprise should augment Forum of Incident Response and Security Teams, Inc.'s (FIRST) Common Vulnerability Scoring System (CVSS) with data concerning the likelihood of a threat actor using a vulnerability, or potential impact of an exploit to the enterprise. Information on the likelihood of exploitation should also be periodically updated based on the most current threat information. For example, the release of a new exploit, or new intelligence relating to exploitation of the vulnerability, should change the priority through which the vulnerability should be considered for patching. Various commercial systems are available to allow an enterprise to automate and maintain this process in a scalable manner.

The most effective vulnerability scanning tools compare the results of the current scan with previous scans to determine how the vulnerabilities in the environment have changed over time. Security personnel use these features to conduct vulnerability trending from month to month.

Finally, there should be a quality assurance process to verify configuration updates, or that patches are implemented correctly and across all relevant enterprise assets.

Safeguards

Safeguard 7.1: Establish and Maintain a Vulnerability Management Process

Asset Type:	Documentation	Security Function:	Govern	IG1	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----	-----

Establish and maintain a documented vulnerability management process for enterprise assets. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 7.2: Establish and Maintain a Remediation Process

Asset Type:	Documentation	Security Function:	Govern	IG1	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----	-----

Establish and maintain a risk-based remediation strategy documented in a remediation process, with monthly, or more frequent, reviews.

Safeguard 7.3: Perform Automated Operating System Patch Management

Asset Type:	Software	Security Function:	Protect	IG1	IG2	IG3
-------------	----------	--------------------	---------	-----	-----	-----

Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.

Safeguard 7.4: Perform Automated Application Patch Management

Asset Type: Software	Security Function: Protect	IG1 IG2 IG3
-----------------------------	-----------------------------------	----------------------------------

Perform application updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.

Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets

Asset Type: Software	Security Function: Identify	IG2 IG3
-----------------------------	------------------------------------	-----------------------

Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans.

Safeguard 7.6: Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets

Asset Type: Software	Security Function: Identify	IG2 IG3
-----------------------------	------------------------------------	-----------------------

Perform automated vulnerability scans of externally-exposed enterprise assets. Perform scans on a monthly, or more frequent, basis.

Safeguard 7.7: Remediate Detected Vulnerabilities

Asset Type: Software	Security Function: Respond	IG2 IG3
-----------------------------	-----------------------------------	-----------------------

Remediate detected vulnerabilities in software through processes and tooling on a monthly, or more frequent, basis, based on the remediation process.

CONTROL 8

Audit Log Management

Safeguards: 12	IG1: 3/12	IG2: 11/12	IG3: 12/12
----------------	-----------	------------	------------

Overview

Collect, alert, review, and retain audit logs of events that could help detect, understand, or recover from an attack.

Why is this Control critical?

Log collection and analysis is critical for an enterprise’s ability to detect malicious activity quickly. Sometimes audit records are the only evidence of a successful attack. Attackers know that many enterprises keep audit logs for compliance purposes, but rarely analyze them. Attackers use this knowledge to hide their location, malicious software, and activities on victim machines. Due to poor or nonexistent log analysis processes, attackers sometimes control victim machines for months or years without anyone in the target enterprise knowing.

There are two types of logs that are generally treated and often configured independently: system logs and audit logs. System logs typically provide system-level events that show various system process start/end times, crashes, etc. These are native to systems, and take less configuration to turn on. Audit logs typically include user-level events—when a user logged in, accessed a file, etc.—and take more planning and effort to set up.

Logging records are also critical for incident response. After an attack has been detected, log analysis can help enterprises understand the extent of an attack. Complete logging records can show, for example, when and how the attack occurred, what information was accessed, and if data was exfiltrated. Retention of logs is also critical in case a follow-up investigation is required or if an attack remained undetected for a long period of time.

Procedures and tools

Most enterprise assets and software offer logging capabilities. Such logging should be activated, with logs sent to centralized logging servers. Firewalls, proxies, and remote access systems (Virtual Private Network (VPN), dial-up, etc.) should all be configured for verbose logging where beneficial. Retention of logging data is also important in the event an incident investigation is required.

Furthermore, all enterprise assets should be configured to create access control logs when a user attempts to access resources without the appropriate privileges. To evaluate whether such logging is in place, an enterprise should periodically scan through its logs and compare them with the enterprise asset inventory assembled as part of CIS Control 1, in order to ensure that each managed asset actively connected to the network is periodically generating logs.

Safeguards

Safeguard 8.1: Establish and Maintain an Audit Log Management Process

Asset Type:	Documentation	Security Function:	Govern	IG1	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----	-----

Establish and maintain a documented audit log management process that defines the enterprise’s logging requirements. At a minimum, address the collection, review, and retention of audit logs for enterprise assets. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 8.2: Collect Audit Logs

Asset Type:	Data	Security Function:	Detect	IG1	IG2	IG3
-------------	------	--------------------	--------	-----	-----	-----

Collect audit logs. Ensure that logging, per the enterprise’s audit log management process, has been enabled across enterprise assets.

Safeguard 8.3: Ensure Adequate Audit Log Storage

Asset Type:	Data	Security Function:	Protect	IG1	IG2	IG3
-------------	------	--------------------	---------	-----	-----	-----

Ensure that logging destinations maintain adequate storage to comply with the enterprise’s audit log management process.

Safeguard 8.4: Standardize Time Synchronization

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Standardize time synchronization. Configure at least two synchronized time sources across enterprise assets, where supported.